SE Lab 5 — Static Code Analysis Report

Retail Point of Sale & Discount Tracker

Student: Pratham P Shetty **SRN:** PES2UG24CS370

Repository: SETAPESU26/L5_02_retail_pos

Important verification note

This report does not pretend to contain captured output from the three tools. The repository source was inspected, but the execution environment had no Pylint, Bandit, or Flake8 installation and could not access package downloads. The findings below are a manual source review, not authentic CLI output. Run the commands in the final section on your computer to produce the required tool output.

1. Pylint — code quality

Command to run:

```
pylint pos_system.py
```

Review findings relevant to Pylint: unused import (`json`); function naming inconsistency (`printSales`); missing docstrings and inconsistent formatting in the starter; mutable default argument; broad exception handling. Exact message IDs and score must be captured by running Pylint locally.

2. Bandit — security

Command to run:

```
bandit -r pos_system.py
```

Primary security concern in the starter: `eval(code_str)` evaluates promo input as Python code. This was replaced in the cleaned file with a restricted AST evaluator that only accepts `total`, numbers, and basic arithmetic. Exact Bandit severity/confidence output must be captured from a real run.

3. Flake8 — style and formatting

Command to run:

```
flake8 pos_system.py
```

Likely style areas in the starter include unused imports, missing blank-line conventions, spacing, and naming/formatting consistency. The revised file was formatted for conventional Python style, but exact Flake8 output and line numbers must be confirmed by running the tool.

Summary of source issues and fixes

Issue	Fix applied
Unsafe eval	Restricted AST arithmetic evaluator; arbitrary expressions rejected.
Bare/broad exceptions	Explicit input checks and meaningful ValueError exceptions.
Mutable default list	Default changed to None; local list initialized per call.
Unclosed log file	Context manager and UTF-8 encoding.
Bad quantities/tax	Positive integer quantity and tax-rate validation.
Style / unused import	Removed unused import, added docstrings, f-strings, snake_case.

Commands to generate the actual output files

```
python -m pip install pylint bandit flake8
pylint pos_system.py > pylint_report.txt
bandit -r pos_system.py > bandit_report.txt
flake8 pos_system.py > flake8_report.txt
```

After running the commands, save the three `.txt` files and include them with this PDF if your instructor requires literal tool output.